

Relatório de Auditoria de Segurança — English School System

Auditoria técnica do código-fonte

Data: 30/08/2026

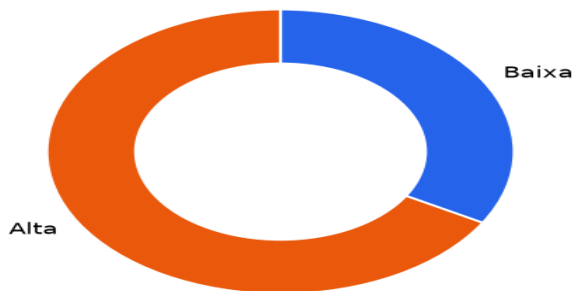
Escopo: Next.js 16, React/TypeScript, NextAuth JWT, Prisma/PostgreSQL, APIs, frontend, Docker Compose, CI, documentação e histórico Git.

Nota metodológica: as categorias foram mapeadas para queries Prisma sem RLS explícito, guards server-side NextAuth, gates de UI, renderização HTML/URLs e credenciais de deploy.

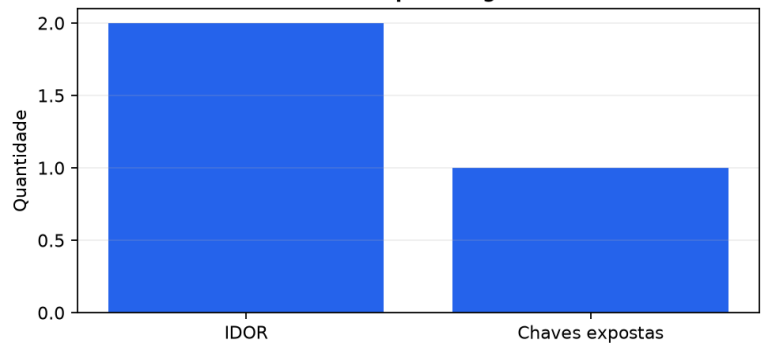
Resumo executivo

Foram verificados 33 handlers em `src/app/api/**/route.ts`, serviços relacionados, schema Prisma, gates de frontend, configuração de ambiente, Docker/CI/documentação e histórico Git. Foram confirmados 3 achados acionáveis: 2 de alta severidade relacionados a autorização/posse e 1 de baixa severidade relacionado a credencial padrão de desenvolvimento.

Achados por severidade



Achados por categoria



Não foram encontrados achados verificados de XSS nos pontos HTML analisados, nem chaves de produção hardcoded no bundle/documentação examinados. A credencial do Compose é um risco condicionado ao uso fora de ambiente local isolado.

Pontos fortes

Autenticação e RBAC — `src/lib/auth-helpers.ts:14-25` e `src/proxy.ts:7-63`
NextAuth valida sessão no servidor; proxy restringe páginas por papel; handlers sensíveis usam `getAuthenticatedUser/isAdmin`.

Validação de entrada — `src/lib/validations.ts` e rotas API
Há schemas Zod para payloads sensíveis, incluindo a ação de sessão live.

XSS em conteúdo rico — `src/lib/sanitize-html.ts:6-31`; `src/app/blog/[slug]/page.tsx:99-103`
DOMPurify é aplicado imediatamente antes de `dangerouslySetInnerHTML`, com tags/atributos/URLs restritos.

Segredos em produção — `src/lib/env.ts:6-39`
`DATABASE_URL`, `NEXTAUTH_SECRET` e `ENCRYPTION_KEY` têm validação de tamanho/presença; produção lança erro em configuração inválida.

Rate limiting e webhook — `src/app/api/recordings/[id]/route.ts:16-22`;
`src/app/api/webhooks/stripe/route.ts`
Endpoints mutáveis usam rate limit; Stripe possui rota dedicada para webhook.

Pontos fracos centrais

Os guards de escrita delegam a autorização a serviços que tratam um `teacherId` opcional como suficiente. A camada de rota confirma o papel, mas não confirma a existência do perfil Teacher antes de chamar a operação. Isso cria uma falha de negação implícita: identidade parcial não é rejeitada.

Achados detalhados

Severidade/ b>	Arquivo:linha	Descrição verificada
ALTA	src/services/recording.service.ts:157-161 IDOR / autorização server-side	Exclusão de gravação aceita professor sem identidade resolvida Quando a rota recebe um usuário TEACHER sem registro correspondente em Teacher, teacherId permanece undefined. A condição não rejeita o chamador e a operação delete usa somente o ID fornecido. Evidência: if (!isAdmin && teacherId && recording.teacherId !== teacherId) { throw new Error('UNAUTHORIZED')}
ALTA	src/services/live-session.service.ts:124-128 e 144-148 IDOR / autorização server-side	Início/fim de sessão aceita professor sem identidade resolvida A rota exige papel TEACHER, mas teacher?.id é opcional. Se o usuário não possui perfil Teacher, teacherId fica undefined e o guard é bypassado. Evidência: if (!isAdmin && teacherId && session.teacherId !== teacherId) { throw new Error('UNAUTHORIZED')}
BAIXA	docker-compose.yml:7 Chaves expostas	Credencial padrão de PostgreSQL versionada em configuração de desenvolvimento A senha é pública no repositório e é usada automaticamente pelo serviço PostgreSQL local. Se o compose for exposto, reutilizado fora de ambiente isolado ou combinado com uma porta publicada, a credencial deixa de ser apenas fixture. Evidência: POSTGRES_PASSWORD: english_school_dev

Categorias sem achado confirmado

Banco sem tranca: não há RLS; o isolamento é implementado por filtros manuais por userId/role. A auditoria encontrou os dois bypasses acima, mas não confirmou outra listagem sem escopo nos handlers revisados. Permissão definida no navegador: os endpoints sensíveis possuem validação server-side; ocultar UI não é considerado proteção. XSS: categoria aplicável ao frontend, mas os sinks encontrados usam sanitizeRichHtml.

Recomendações priorizadas

P1 — Corrigir os dois guards de serviço para falhar fechado e condicionar a escrita à posse.

P2 — Adicionar testes de autorização por objeto para cada rota PATCH/DELETE e para professor sem perfil relacionado.

P3 — Remover a senha fixa do Compose, parametrizar via variável local não versionada e manter a porta do Postgres fechada por padrão.

P4 — Manter a validação de ambiente em produção e expandir a revisão periódica de sinks HTML, URLs e bundles.

Cobertura e condições

Foram considerados todos os 33 arquivos route.ts encontrados. Rotas públicas (health, autenticação, registro, blog e webhook) foram tratadas conforme sua função; webhook depende de assinatura Stripe e endpoints de autenticação aplicam rate limiting/validação. O histórico Git consultado não apresentou segredo real confirmado; commits de hardening e testes foram tratados como contexto, não como prova de segurança atual.

ISSUES PARA O GITHUB

As issues abaixo estão completas e delimitadas para cópia direta.

```
--- ISSUE 1 --- # [Segurança] Exclusão de gravação aceita professor sem identidade resolvida **Labels sugeridas:** `security`, `severity:alta` ## Descrição Quando a rota recebe um usuário TEACHER sem registro correspondente em Teacher, teacherId permanece undefined. A condição não rejeita o chamador e a operação delete usa somente o ID fornecido. ## Evidência `src/services/recording.service.ts:157-161` ``ts if (!isAdmin && teacherId && recording.teacherId !== teacherId) { throw new Error('UNAUTHORIZED') } `` ## Impacto Um professor autenticado sem vínculo Teacher pode excluir qualquer Recording cujo ID conheça. ## Sugestão de correção Falhar fechado quando teacherId estiver ausente; melhor ainda, fazer deleteMany/update condicionado por teacherId e validar posse na mesma operação. ## Critérios de aceite - [ ] O servidor rejeita identidade ausente ou inconsistente com HTTP 403. - [ ] A operação verifica posse/escopo no mesmo comando de escrita. - [ ] Teste automatizado cobre ID de outro usuário e perfil sem vínculo. - [ ] Logs de auditoria registram a tentativa sem expor segredos. --- FIM ISSUE 1 ---
```

```
--- ISSUE 2 --- # [Segurança] Início/fim de sessão aceita professor sem identidade resolvida **Labels sugeridas:** `security`, `severity:alta` ## Descrição A rota exige papel TEACHER, mas teacher?.id é opcional. Se o usuário não possui perfil Teacher, teacherId fica undefined e o guard é bypassado. ## Evidência `src/services/live-session.service.ts:124-128 e 144-148` ``ts if (!isAdmin && teacherId && session.teacherId !== teacherId) { throw new Error('UNAUTHORIZED') } `` ## Impacto O chamador pode alterar o status de qualquer LiveSession por ID, iniciando ou encerrando aulas alheias. ## Sugestão de correção Retornar 403 se não existir Teacher; validar a relação teacherId na query de update e rejeitar qualquer identidade incompleta. ## Critérios de aceite - [ ] O servidor rejeita identidade ausente ou inconsistente com HTTP 403. - [ ] A operação verifica posse/escopo no mesmo comando de escrita. - [ ] Teste automatizado cobre ID de outro usuário e perfil sem vínculo. - [ ] Logs de auditoria registram a tentativa sem expor segredos. --- FIM ISSUE 2 ---
```

```
--- ISSUE 3 --- # [Segurança] Credencial padrão de PostgreSQL versionada em configuração de desenvolvimento **Labels sugeridas:** `security`, `severity:baixa` ## Descrição A senha é pública no repositório e é usada automaticamente pelo serviço PostgreSQL local. Se o compose for exposto, reutilizado fora de ambiente isolado ou combinado com uma porta publicada, a credencial deixa de ser apenas fixture. ## Evidência `docker-compose.yml:7` ``ts POSTGRES_PASSWORD: english_school_dev `` ## Impacto Acesso não autorizado ao banco de desenvolvimento e possível reutilização acidental em ambientes compartilhados. ## Sugestão de correção Ler a senha de variável obrigatória/arquivo local não versionado, remover a publicação da porta por padrão e rejeitar valores conhecidos em ambientes não locais. ## Critérios de aceite - [ ] O servidor rejeita identidade ausente ou inconsistente com HTTP 403. - [ ] A operação verifica posse/escopo no mesmo comando de escrita. - [ ] Teste automatizado cobre ID de outro usuário e perfil sem vínculo. - [ ] Logs de auditoria registram a tentativa sem expor segredos. --- FIM ISSUE 3 ---
```